

SENTINAL SECURITY ASSESSMENT REPORT

Project: Scope: NodeGoat | Type: COMBINED | Date: 2026-09-03 09:15 UTC

Overall Risk Score	Critical	High	Medium	Low	Total Findings
59.5/100	0	1	1	1	4

1. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:**** ELEVATED RISK

The assessment revealed notable security weaknesses across http://demo.owasp-juice.shop?utm_source=chatgpt.com, comprising 1 High and 1 Medium issues.

****Key Risk Highlights:****

- Total Discovered Findings: 4 (Critical: 0, High: 1, Medium: 1, Low: 1)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Security Misconfiguration, Cryptographic Failures, Information Disclosure

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

3. Findings Inventory

Sev	Source	Vulnerability	Location / Remediation
HIGH	SSL	Target Service Operates Over Unencrypted HTTP The application endpoint serves traffic over unencrypted plaintext HTTP, exposing sensitive communications to eavesdropp	/ <i>Fix:</i> Configure a TLS certificate and redirect all HTTP traffic to HTTPS (Port 443).
MEDIUM	WEB	Missing Content Security Policy (CSP) Header A Content Security Policy restricts sources of executable scripts, stylesheets, and frames, preventing Cross-Site Script	/ <i>Fix:</i> Implement a strong `Content-Security-Policy` header (e.g. `default-src 'self'; script-src 'self'; ob
LOW	WEB	Missing Referrer-Policy Header The Referrer-Policy header controls how much referrer information (sent via the Referer header) should be included with	/ <i>Fix:</i> Configure the web server (Nginx/Apache/Cloudflare) to suppress or sanitize the Server banner.
INFO	WEB	Missing Permissions-Policy Header The Permissions-Policy header allows sites to restrict access to browser features such as camera, microphone, geolocatio	/ <i>Fix:</i> Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()` to disable unused browser A